

Report 09 — Risk Assessment and Recommendations

Project: SIEM Correlation Rules — ELK Stack **Date:** 2026-07-07 | **Log Date:** 2026-06-15 **Version:** 1.0

Table of Contents

- [1. Risk Assessment Overview](#)
 - [2. Risk Register](#)
 - [3. Impact Analysis](#)
 - [4. Immediate Response Actions](#)
 - [5. Short-Term Mitigations](#)
 - [6. Long-Term Security Improvements](#)
 - [7. Best Practices](#)
 - [8. Future SIEM Improvements](#)
-

1. Risk Assessment Overview

Risk is assessed using a 5×5 matrix combining **Likelihood** (1–5) and **Impact** (1–5) to produce a **Risk Score** (1–25).

Risk Level	Score	Colour
Critical	20–25	Red
High	13–19	● Orange
Medium	7–12	● Yellow
Low	1–6	● Green

2. Risk Register

Risk ID	Risk Description	Category	Likelihood (1–5)	Impact (1–5)	Risk Score	Level	Current Detection	Priority
R-001	Domain Controller compromise via PowerSh	PowerShell	5	5	25	Critical	PS-002 fires	Immediate

Risk ID	Risk Description	Category	Likelihood (1–5)	Impact (1–5)	Risk Score	Level	Current Detection	Priority
	ell download cradle							
R-002	Active DNS tunnelling C2 across 30+ hosts	DNS	5	5	25	Critical	DNT-001 /002 fire	Immediate
R-003	Malware binary (update.exe) dropped on multiple hosts	PowerShell	5	5	25	Critical	PS-002 fires	Immediate
R-004	Service account (svc_backup) fully compromised	Credential	5	4	20	Critical	CS-004, PS-002	Immediate
R-005	Five domain accounts locked out — stuffing campaign active	Credential	5	4	20	Critical	CS-003 fires	Immediate
R-006	Office macro-based initial access across 10+ host/user pairs	PowerShell	5	4	20	Critical	PS-003 fires	Immediate
R-007	regsvr32/rundll32 LOLBAS payload execution	PowerShell	5	4	20	Critical	PS-004/005 fire	Immediate

Risk ID	Risk Description	Category	Likelihood (1–5)	Impact (1–5)	Risk Score	Level	Current Detection	Priority
R-008	Persistent encrypted C2 to 103.68.22.9 and 91.203.145.12	Network	4	5	20	Critical	Partial only	High
R-009	SSH brute force from Tor exit node (185.220.101.47)	Credential	5	3	15	● High	CS-001 fires	High
R-010	Potential LSASS credential dump from compromised DC	Credential	4	5	20	Critical	Not detected	Immediate
R-011	Attacker persistence via scheduled tasks/registry (assumed)	Persistence	3	5	15	● High	Not detected	High
R-012	AD user database exported (Get-ADUser)	Discovery	4	4	16	● High	Adjacent to PS-002	High
R-013	Internal network scanning from 45.146.164.110	Network	3	3	9	● Medium	Firewall blocks	Medium
R-014	DNS-over-HTTPS tunnelling bypassing	DNS	4	4	16	● High	DNT-004 fires	High

Risk ID	Risk Description	Category	Likelihood (1–5)	Impact (1–5)	Risk Score	Level	Current Detection	Priority
	DNS monitoring							
R-015	SeDebug Privilege assigned to svc_backup and svc_sql	Privilege	3	4	12	● Medium	Partially (4672 logged)	Medium

3. Impact Analysis

3.1 Business Impact by Risk

Risk	Business Impact	Data at Risk	Availability Impact
R-001 (DC compromise)	Full domain takeover; all accounts, GPOs, trusts at risk	All CORP domain credentials and data	Complete — attacker can cause total outage
R-002 (DNS C2)	Sustained data exfiltration; attacker has persistent access	Any data accessible to compromised hosts	Low — tunnelling is stealthy
R-003 (update.exe)	Ransomware or destructive malware possible	All files accessible to svc_backup and kpatel	High if ransomware deployed
R-004 (svc_backup)	Backup infrastructure compromised; recovery impossible if backup deleted	All backup data	Critical — backup deletion possible
R-008 (C2 ESTABLISHED)	Long-running C2 session; attacker may have had access for hours	All data on compromised host	Low — stealthy persistence
R-012 (AD export)	Complete user inventory exfiltrated; enables targeted phishing	All user account details	None direct

3.2 Compromised Hosts Summary

Host	Compromise Evidence	Recommended Action
SRV-DC01	IEX DownloadString (04:51, 04:59) by jsmith and nreddy	Isolate and rebuild. Treat as fully compromised.
SRV-APP05	PS download cradle (svc_backup), regsvr32, EXCEL-spawned PS	Isolate. Forensic imaging. Rebuild.
WKS-SALES22	IEX DownloadString (rgupta), regsvr32 (jsmith), PS from macros	Isolate. Reimage.
SRV-FILE02	PS from EXCEL (nreddy), regsvr32 (rgupta), rundll32	Isolate. Forensic imaging. Rebuild.
WKS-ENG14	PS from WINWORD (svc_sql), rundll32 (rgupta)	Isolate. Reimage.
WKS-FIN07	Encoded PS (tverma, svc_sql, kpatel), DownloadFile update.exe	Isolate. Reimage.
WKS-HR03	PS engine events, amehta sudo abuse	Investigate. Possible reimage.

4. Immediate Response Actions

These actions must be completed within 24 hours of detection:

1. **Isolate SRV-DC01 from the network** — disconnect from all network interfaces except a management VLAN. The domain controller has executed malicious PowerShell from two user accounts. A compromised DC gives the attacker the ability to create new domain admin accounts, forge Kerberos tickets (Golden Ticket), and persist indefinitely.
2. **Reset the krbtgt account password TWICE** — even if it is uncertain whether the attacker extracted the krbtgt hash, this is mandatory after a DC compromise to invalidate all existing Kerberos tickets. Reset once, wait 10 hours, then reset again.
3. **Force password resets for all compromised accounts** — disable and reset: jsmith, rgupta, nreddy, kpatel, tverma, svc_backup, svc_sql, dwilson, lchen, amehta. Session tokens must be invalidated.
4. **Block all known threat actor IPs at the perimeter firewall** — add permanent DENY rules for:
 - 185.220.101.47 (inbound and outbound)
 - 103.68.22.9 (outbound)
 - 45.146.164.110 (inbound and outbound)
 - 91.203.145.12 (outbound)

5. **Sinkhole `cdn-sync-update.net` and `malicious-update-cdn.net` at DNS** — add RPZ (Response Policy Zone) entries to return NXDOMAIN for all queries to these domains and their subdomains. This immediately cuts the DNS C2 channel.
6. **Delete and quarantine `update.exe` from all Temp directories** — hash `update.exe` and create an AV/EDR signature. Check: C:
 \Users\svc_backup\AppData\Local\Temp\, C:
 \Users\kpatel\AppData\Local\Temp\.
7. **Enable enhanced logging immediately** on all remaining hosts — verify Sysmon is deployed with Event IDs 1, 3, 7, 10, 11, 12, 13, 22. Enable PowerShell Script Block Logging if not already active on all hosts.

5. Short-Term Mitigations

Complete within 2 weeks:

#	Mitigation	Target	Expected Outcome
1	Deploy MFA for all SSH access via TOTP or hardware key	All Linux servers	Eliminates password-based SSH brute force
2	Configure Fail2Ban on all Linux servers (ban after 5 failures / 60 s)	bastion01, web-prod01/02, db-prod01, app-prod03, mail-relay01	Automatic IP blocking during brute force
3	Restrict SSH to bastion01 only via iptables on all other Linux hosts	All Linux servers	Eliminates direct SSH attack surface
4	Disable PasswordAuthentication yes in sshd_config on all Linux servers	All Linux servers	Forces key-only SSH auth
5	Enable ASR rule: Block Office apps from creating child processes	All Windows endpoints	Blocks macro-spawned PS, cmd, wscript
6	Deploy AppLocker policy blocking regsvr32 and rundll32 from AppData\Temp	All Windows endpoints	Blocks LOLBAS payload execution
7	Enable PowerShell Constrained Language Mode via WDAC	All Windows endpoints	Blocks Net.WebClient, Add-Type, IEX
8	Enforce proxy policy blocking downloads	Corporate proxy	Blocks download cradle payload delivery

#	Mitigation	Target	Expected Outcome
	of .ps1 and .exe from external domains		
9	Implement AD tiering (Tier 0/1/2) — service accounts must not log onto workstations	Active Directory	Reduces blast radius of svc_backup/svc_sql compromise
10	Rotate all service account passwords and enforce 90-day rotation policy	svc_backup, svc_sql, all service accounts	Limits window of credential use after theft

6. Long-Term Security Improvements

Complete within 3–6 months:

Improvement	Description	Benefit
Zero Trust Network Architecture	Implement micro-segmentation — workstations cannot communicate directly with servers on SMB/445 without explicit policy	Prevents lateral movement even if endpoint is compromised
EDR Deployment (Microsoft Defender for Endpoint or CrowdStrike)	Full endpoint detection and response on all Windows and Linux hosts	Closes all log source gaps — LSASS, DLL injection, file creation
Privileged Access Workstations (PAW)	Dedicated hardened workstations for admin tasks; no email/browser access	Eliminates macro-based initial access for privileged users
Deception Technology	Deploy honeytokens (fake AD credentials, fake files) that alert on access	Early warning of lateral movement before damage occurs
SOAR Playbook Automation	Automate CS-003 response: trigger AD lockout review + Slack alert within 2 min of firing	Reduces mean time to respond (MTTR) from hours to minutes
DNS-over-HTTPS Monitoring	Deploy Zeek with SSL certificate inspection to identify DoH traffic to non-approved providers	Closes DNT-004 detection gap for hosts not using corporate proxy
User and Entity Behaviour Analytics (UEBA)	Baseline user behaviour and alert on deviations (unusual logon hours, new countries, privilege use)	Detects compromised accounts even without specific technique signatures
Threat Intelligence Platform	Subscribe to MISP, OpenCTI or	Proactive blocking of threat

Improvement	Description	Benefit
	commercial TI feeds; auto-block newly identified C2 IPs	infrastructure before it targets CORP

7. Best Practices

7.1 Credential Security

Practice	Implementation	Standard
Multi-Factor Authentication	Enforce for all privileged access, SSH, RDP, VPN	NIST SP 800-63B
Password Manager	Enterprise password manager for all service accounts	CIS Control 5
Credential Monitoring	Subscribe to breach notification services (HIBP Enterprise)	ISO 27001 A.9.4
Privileged Account Segregation	Separate admin accounts from standard user accounts	CIS Control 5.4
Just-In-Time Privileged Access	Use PAM solutions (CyberArk, BeyondTrust) for time-limited elevation	Zero Trust principle

7.2 PowerShell Hardening

Practice	Configuration	Impact
Script Block Logging	HKLM: \SOFTWARE\Policies\Microsoft\Windows\PowerShell\ScriptBlockLogging\EnableScriptBlockLogging = 1	Full script capture in Event 4104
Module Logging	HKLM: \SOFTWARE\Policies\Microsoft\Windows\PowerShell\ModuleLogging\EnableModuleLogging = 1	Cmdlet parameter capture in Event 4103
Transcription	Enable PS transcription to a central share	Full session history
Constrained Language Mode	Enforce via WDAC policy	Blocks most attack techniques
Remove PowerShell v2	Disable- WindowsOptionalFeature -Online -FeatureName	Removes AMSI bypass via v2 downgrade

Practice	Configuration	Impact
	MicrosoftWindowsPowerShellV2Root	

7.3 DNS Security

Practice	Implementation
DNSSEC	Enable DNSSEC validation on dns-srv01
DNS Response Policy Zones	Block known C2 domains dynamically via RPZ feeds
DNS Logging	Log all queries, responses, and TTL values to SIEM
DNS Rate Limiting	Enable BIND <code>rate-limit { responses-per-second 10; }</code>
Split DNS	Internal DNS for corp.local; strict forwarder policy for external
DoH Allowlist	Block all DoH except approved providers at proxy level

8. Future SIEM Improvements

Improvement	Description	Priority
ML-Based DNS Anomaly Detection	Train a model on baseline DNS patterns; score each query for deviation	High
Automated Threat Intelligence Enrichment	Feed IOCs from AlienVault OTX, Abuse.ch into Elasticsearch enrichment policy	High
SOAR Integration (TheHive + Cortex)	Automatically create incidents from Critical alerts; run automated enrichment	Medium
Network Traffic Analysis (Zeek full capture)	Full packet metadata for all east-west and north-south traffic	High
Asset Inventory Integration	Enrich alerts with asset owner, business unit, criticality tier	Medium
Risk-Based Alerting	Weight alert severity by asset criticality (SRV-DC01 alerts score higher)	Medium
Scheduled Threat Hunting	Weekly automated hunt queries for new IOCs and ATT&CK	Medium

Improvement	Description	Priority
	techniques	
Purple Team Exercises	Regular adversary simulation using Atomic Red Team to validate rule coverage	High